Access Control – Risk Rating: Moderate

Framework Mapping: PR.AA-05: Access permissions, entitlements, and authorizations are defined in a policy, managed, enforced, and reviewed, and incorporate the principles of least privilege and separation of duties

- GAP: Under section three of the policy, there is not a specific timeframe in which the access management review should be conducted, who is responsible for conducting the review, and any documentation required as evidence it's been conducted. There is also no exception to handling procedures.
- POTENTIAL GAP IMPACT: Without an established access review time, no one is specifically responsible for conducting the access review, and no documented exceptions. There is no way to tell if inappropriate access has been removed. Data could be misused intentionally and unintentionally, causing avoidable risks to NSF.
- RECOMMENDATION: Immediately conduct a review and remove unnecessary access. Set a quarterly timeline for the review and require all activity to be documented and signed off by team lead in charge of handling said review. I would create alerts for employees changing roles and off-boarding employees to ensure the proper access is being given to the right person and taken away if that person moves on from the company.

Password Management – Risk Rating: High

Framework Mapping: PR.AA-03: Users, services, and hardware are authenticated

- GAP: Under section 4 of policy, there are no specific criteria for passwords to be considered "strong" and there is no system provided to identify and escalate a compromised password.
- POTENTIAL GAP IMPACT: With no criteria for passwords, employees could mistakenly use a password that is not "strong" and become susceptible to being compromised. Also, no system provided to identify those compromised passwords and escalate them to the proper department can lead to missed data breaches.

Long exposure to data breaches can lead to disrupted operations, exposed customer data, and loss of trust from stakeholders.

- RECOMMENDATION: Establish minimum password length and strength requirements. Make systems reject commonly used passwords. Implement process to detect and escalate and remediate compromised passwords. Require MFA where needed.

Data Protection – Risk Rating: High

Framework Mapping: PR.DS-01, PR.DS-02: The confidentiality, integrity, and availability of data-at-rest are protected. The confidentiality, integrity, and availability of data-in-transit are protected

- GAP: Under section 6 of the policy, there is no specific procedure for sharing sensitive information. There are also no criteria for what qualifies as an "authorized individual" or "legitimate business need."
- POTENTIAL GAP IMPACT: Without a procedure for sharing sensitive information, data could be sent through less secure means and potentially exposed. Also, with no criteria for what an "authorized individual" is or what a "legitimate need" is, data could be improperly shared to the wrong person causing a potential data breach.
- RECOMMENDATION: Create a procedure for sharing sensitive information, including the proper escalation before sharing sensitive information. Also build a criterion for what a "authorized individual" is and what qualifies as a "legitimate business need." Require sign offs by manager before sharing any sensitive information.

Encryption – Risk Rating: Medium

Framework Mapping: PR.DS-01, PR.DS-02

- GAP: Under policy section seven, when sensitive information should be encrypted is too vague.

- POTENTIAL GAP IMPACT: Lack of specificity could lead to sensitive information being sent through exposed channels; this could lead to data being leaked and misused.
- RECOMMENDATION: The IT team lead should create definitive guidelines on when encryption occurs and who has authorized access. It should create an alert for sensitive information sent outside of specified channels so it can be remediated.

Vulnerability & Patch Management – Risk Rating: Critical

Framework Mapping: PR.PS-02: Software is maintained, replaced, and removed commensurate with risk

- GAP: Under policy section eight, there is no definitive time upon which security updates are installed and no documentation to support they happened. There are also no documented exceptions with a timeline to revisit.
- POTENTIAL GAP IMPACT: Lack of timeline and documentation could lead to delayed patches and prolong exposed data, making data breaches highly likely.
- RECOMMENDATION: Create a 15-day timeline to close patches -- require documentation and manager to sign off. Document any exceptions with a follow-up date. Create alerts for past due patches and delayed patches.

Security Awareness Training – Risk Rating: Medium

Framework Mapping: PR.AT-01: Personnel are provided with awareness and training so that they possess the knowledge and skills to perform general tasks with cybersecurity risks in mind

- GAP: There is no specific timeline in which employees conduct security awareness training. There is also no way to test if the training that was conducted is being learned and applied.
- POTENTIAL GAP IMPACT: Lack of structured training leads to employees not being able to identify phishing attempts. This could lead to frequent data breaches and customer information being exposed to potential misuse. Also, no follow-up mock phishing

trial to test employee knowledge/awareness means there is no way of reinforcing missed concepts during the training.
- RECOMMENDATION: Conduct quarterly security awareness training and create alerts for anyone past 7 days who missed the training to reschedule. Also conduct mock phishing attempts to weed out anyone who has not retained the material so they could be assigned to retake their security wellness training. All completed training must be signed off by managers. Any delayed training must also be signed off by managers with a documented exception.

Third Party Security – Risk Rating: High

Framework Mapping: GV.SC-04, GV.SC-07: Suppliers are known and prioritized by criticality. The risks posed by a supplier, their products and services, and other third parties are understood, recorded, prioritized, assessed, responded to, and monitored over the course of the relationship.

- GAP: There is no detailed requirement for third-party service providers mentioned within the policy regarding when assessments happen. There is also no recourse for what to do if noncompliance occurs.
- POTENTIAL GAP IMPACT: Without specific guidelines given, third party service providers could potentially violate company policy. This could lead to potential data breaches, misuse of customer data, and loss of trust in stakeholders.
- RECOMMENDATION: The IT team lead should create specific guidelines for third party service providers to follow when conducting business with third parties that protects NSF and its customers—this should be reviewed quarterly and signed off by both parties. They should also input alerts for any missed contract reviews and document any delays; in addition, add alerts for third parties who violate contractual requirements to be remediated.

Incident Reporting – Risk Rating: Medium

Framework Mapping: RS.MA-02: Incident reports are triaged and validated

- GAP: There is no specific channel upon which employees can use to report security incidents. There is also no guideline on what a security incident could consist of to help employees identify what a security incident looks like.
- POTENTIAL GAP IMPACT: With no structured way to report suspected incidents, they could get lost amongst other reports leaving it exposed. Also, employees could be reporting things that aren't necessarily security incidents because of lack of knowledge of what one is.
- RECOMMENDATION: The IT team lead should create a document to outline what type of suspicious activity should be reported and provide a structured channel in which to do so. Also, it must be documented for its entire journey to ensure it gets handled in a timely fashion. Any delayed incident responses must have a documented exception.